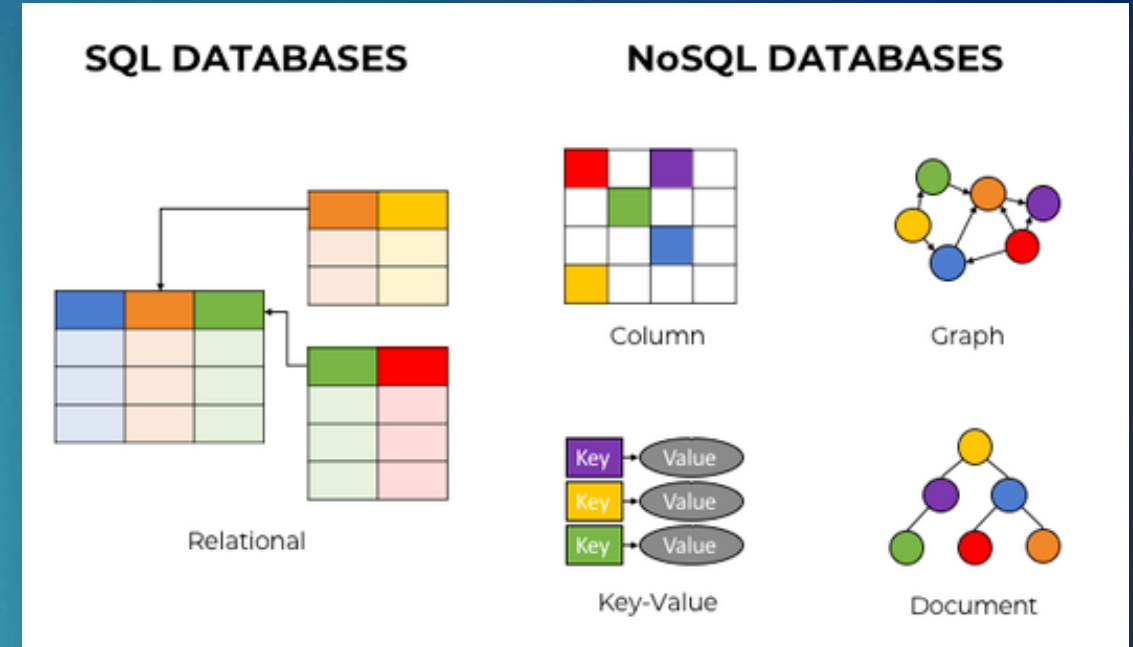


- ▶ SQL (relational) vs NoSQL
- ▶ AWS DB managed services:
 - ▶ SQL - Amazon RDS
 - ▶ NoSQL - DynamoDB (Key-Value), Neptune (Graph), DocumentDB (Document)
 - ▶ Pros - Lower Total Cost Ownership, higher quality as managed by AWS
 - ▶ Cons – Vendor lock-in
- ▶ Which is better?
 - ▶ SQL databases provide great benefits for transactional data whose structure doesn't change frequently (or at all) and where data integrity is paramount
 - ▶ NoSQL databases provide much more flexibility and scalability, which lends itself to rapid development and iteration
 - ▶ Bottom-line: You'll need to think about what your data looks like, how you'll query your data, and the scalability you'll need in the future



Security and Compliance in the Cloud

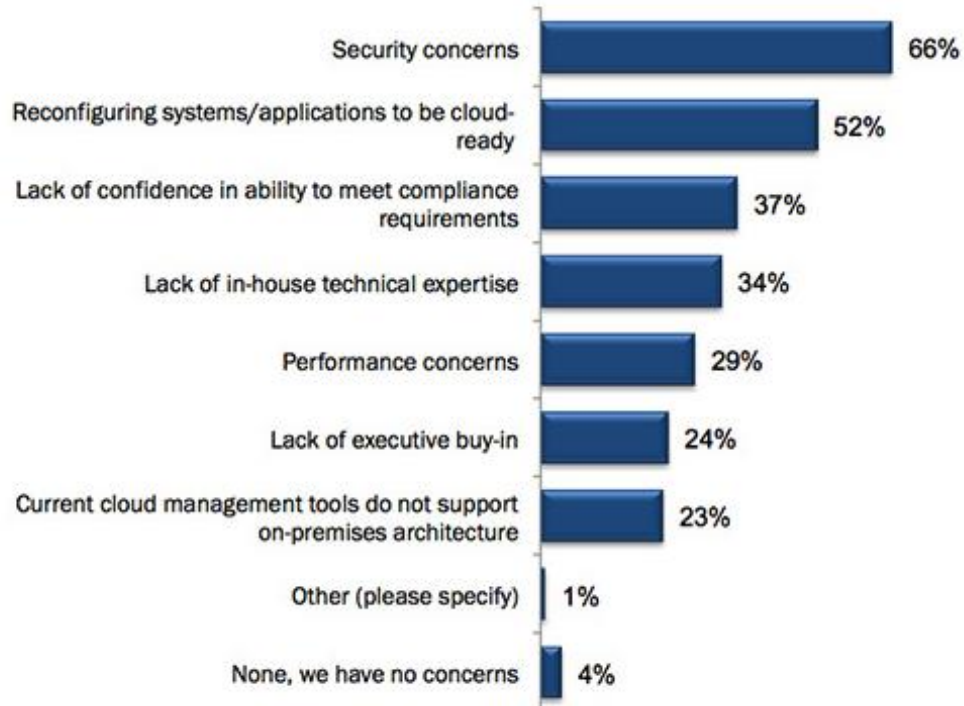
Engineering Cloud Software Systems

Department of Software Engineering
Rochester Institute of Technology

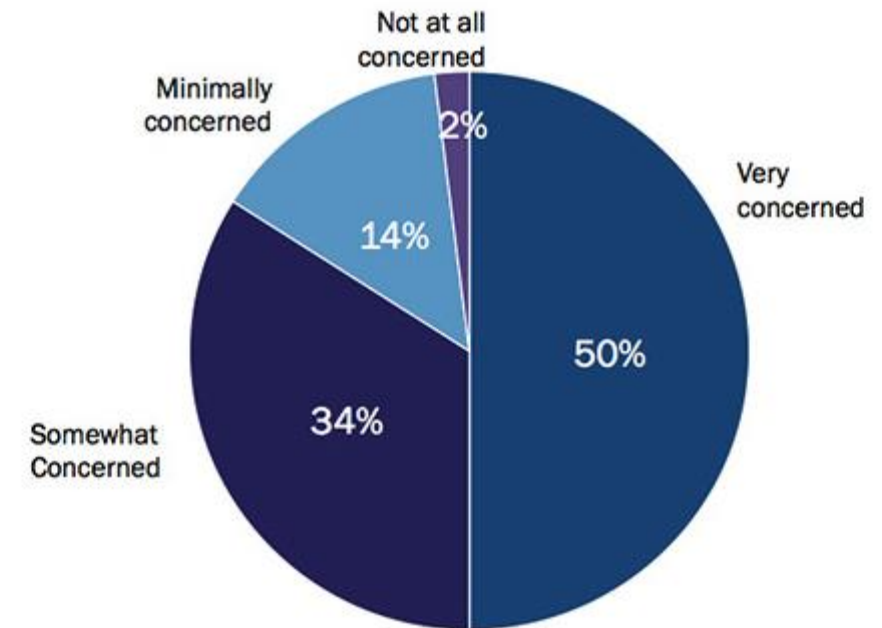


Security is the top concern with organizations moving to the cloud...

Barriers impeding cloud infrastructure deployments



Concern with security of customer data residing in the public cloud



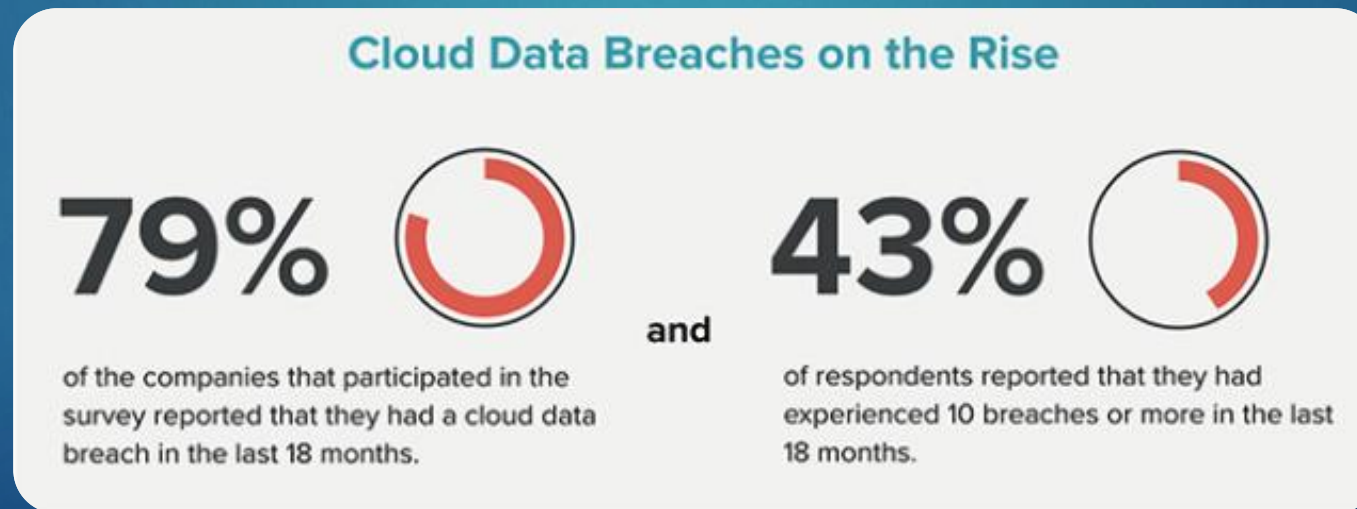
...and for good reason

- ▶ **Accenture (2017)** - World's first Cyber Resilience startup UpGuard discovered in its Cyber Risk survey that Accenture left at least **4 AWS S3 storage buckets unsecured**. As a result of this flaw, the data on these storage media was available for download. The data exposed in this security goof-up were authentication credentials, secret API data, digital certificates, decryption keys, customer data, and other meta info which could be easily used by cyber crooks to mint money.
- ▶ **Verizon (2017)** - Nice Systems, which is a 3rd party vendor working for Verizon, committed a configuration blunder on an **AWS S3 bucket** which exposed names, addresses, account details, and pin numbers of millions of US-based Verizon customers.
- ▶ **Booz Allen Hamilton (2017)** - In this year, technology consulting firm Booz Allen hired UpGuard to carry out security assessment on both its internal and external computer systems. To our surprise, the assessment discovered that 60,000 files were on a public access on **AWS S3 bucket** owned by an intelligence and defense contract of Booz Allen.
- ▶ **Election Systems & Software (ES&S) (2017)** - Virtually every registered voter information from Chicago was available for public access when the engineer working for ES&S left the **AWS S3 bucket** for public access. The data was in downloadable format and is said to have compromised personal info of more than 1.8 million Chicago voters so far.



Cloud Data Breaches

- ▶ According to the 300 CISOs (Chief Information Security Officers) that participated in the survey, top concerns were:
 - ▶ Security misconfiguration
 - ▶ Lack of adequate visibility into access settings and activities
 - ▶ Identity and access management (IAM)
 - ▶ Permission errors



So, who is at fault here?

- ▶ More than 100 million customers have had their data compromised by a hacker after a **cloud misconfiguration** at Capital One
- ▶ Thanks to a cloud misconfiguration, a hacker was able to access to **credit applications, Social Security numbers and bank account numbers** in one of the biggest data breaches to ever hit a financial services company
- ▶ Amazon, for its part, pointed to the admission of misconfiguration in the court documents and the Capital One statement, with a spokesman telling Bloomberg that Capital One's data was not accessed through a vulnerability in AWS systems
- ▶ *"The Capital One breach is proof that companies have a lot to learn when it comes to deploying security technology effectively"*

Former AWS Engineer Arrested as Capital One Admits Massive Data Breach



What is the cloud provider (AWS) responsible for?

- ▶ Protecting the network through automated monitoring systems and robust internet access, to prevent Distributed Denial of Service (DDoS) attacks
- ▶ Performing background checks on employees who have access to sensitive areas
- ▶ Decommissioning storage devices by physically destroying them after end of life
- ▶ Ensuring the physical and environmental security of data centers, including fire protection and security staff



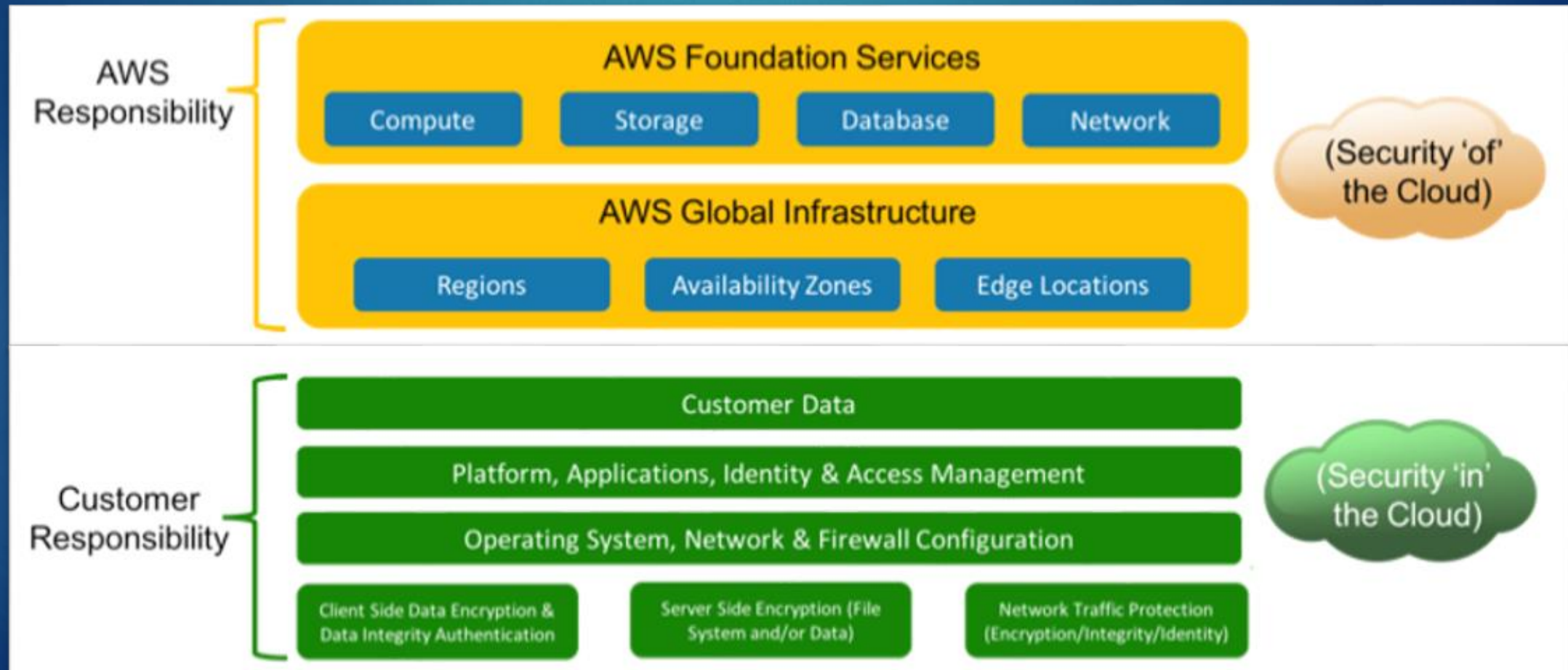
What are you responsible for?

- ▶ Implementing access management that restricts access to AWS resources like S3 and EC2 to a minimum
- ▶ Encrypting data at rest (e.g. database or other storage systems)
- ▶ Encrypting network traffic to prevent attackers from reading or manipulating data (for example, using HTTPS)
- ▶ Configuring a firewall for your virtual network that controls incoming and outgoing traffic with security groups and Access Control Lists (ACLs)
- ▶ Managing patches for the OS and additional software on virtual machines
 - ▶ AWS won't apply updates for you on your EC2 instance – you are responsible for this



Shared Responsibility Model - Infrastructure 11

- ▶ AWS is responsible for security of the cloud
- ▶ The customer is responsible for security in the cloud



Shared Responsibility Model – Service Models

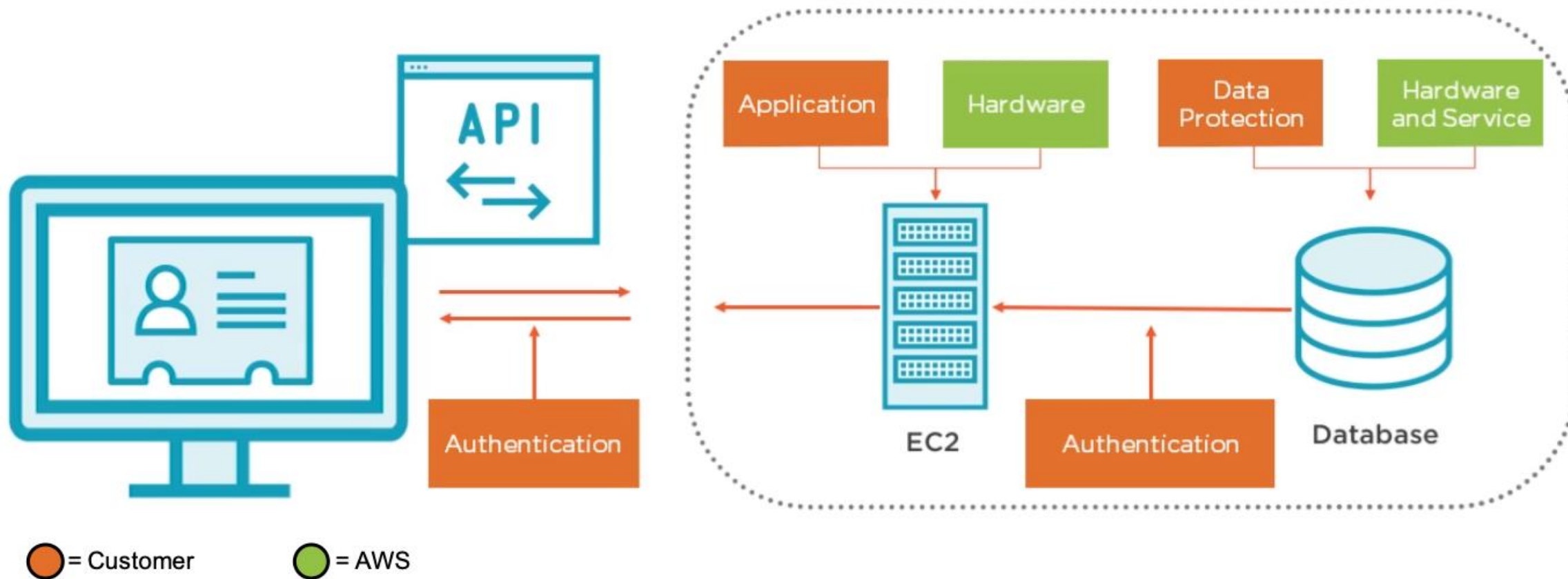
12

Responsibility zones

Responsibility	SaaS	PaaS	IaaS	On-prem	
Data governance & rights management	Customer	Customer	Customer	Customer	Always retained by customer
Client endpoints	Customer	Customer	Customer	Customer	
Account & access management	Customer	Customer	Customer	Customer	
Identity & directory infrastructure	Shared	Shared	Customer	Customer	Varies by service type
Application	Provider	Shared	Customer	Customer	
Network controls	Provider	Shared	Customer	Customer	
Operating system	Provider	Provider	Customer	Customer	
Physical hosts	Provider	Provider	Provider	Customer	Transfers to cloud provider
Physical network	Provider	Provider	Provider	Customer	
Physical datacenter	Provider	Provider	Provider	Customer	
	Provider		Customer		

Shared Responsibility Model - Infrastructure

► Example of a typical Cloud Application



Another Security Challenge...Compliance

14

- ▶ **HIPPA (Health Insurance Portability and Accountability Act)** - a series of regulatory standards that outline the lawful use and disclosure of protected health information
- ▶ **SOX (Sarbanes-Oxley Act)** - established rules to protect the public from fraudulent or erroneous practices by corporations and other business entities
- ▶ **GDPR (General Data Protection Regulation)** - regulation that requires businesses to protect the personal data and privacy of EU citizens for transactions that occur within EU member states
- ▶ **PCI Compliance (Payment Card Industry)** - applies to companies of any size that accept credit card payments
- ▶ **ITAR (International Traffic in Arms Regulations)** - set of U.S. Department of State regulations that control the export of defense and military technologies to safeguard national security and further its foreign policy objectives



Security on AWS

- ▶ Securing access to AWS services and resources
 - ▶ Identity and Access Management (IAM)
- ▶ Securing Applications
 - ▶ AWS Cognito
- ▶ Protecting Data through encryption
 - ▶ Key Management Service (KMS)
- ▶ Compliance
 - ▶ CloudTrail



Understanding Access Controls

- ▶ When you sign up for your own AWS account, you are the root user
- ▶ The root user has unrestricted access to all AWS resources
- ▶ Permissions are not restricted in any way
- ▶ As a best practice, you should lock the root user access so no one can access it
- ▶ Create users/groups that have more restrictive access

What Can Go Wrong?



Your account
can get
compromised



Intruder may
expose all your
data



Intruder may
even delete all
your data and
resources



This can easily
lead to lawsuits
and heavy
financial loss

Identity and Access Management (IAM)

- ▶ IAM is an AWS service that helps an administrator securely control access to AWS resources
- ▶ IAM administrators control who can be authenticated (signed in) and authorized (have permissions) to use certain AWS resources
- ▶ AWS IAM provides the following:
 - ▶ Manage IAM users and their access
 - ▶ You can create users in IAM, assign them individual security credentials and manage permissions in order to control which operations a user can perform
 - ▶ Manage IAM roles and their permissions
 - ▶ You can create roles in IAM and manage permissions to control which operations can be performed by the entity, or AWS service, that assumes the role
 - ▶ Manage federated users and their permissions
 - ▶ You can enable identity federation to allow existing identities (users, groups, and roles) to access the AWS Management Console, call AWS APIs, and access resources



Identity and Access Management (IAM) - Details

19

- ▶ IAM User

- ▶ Used to authenticate people accessing your AWS account

- ▶ IAM Group

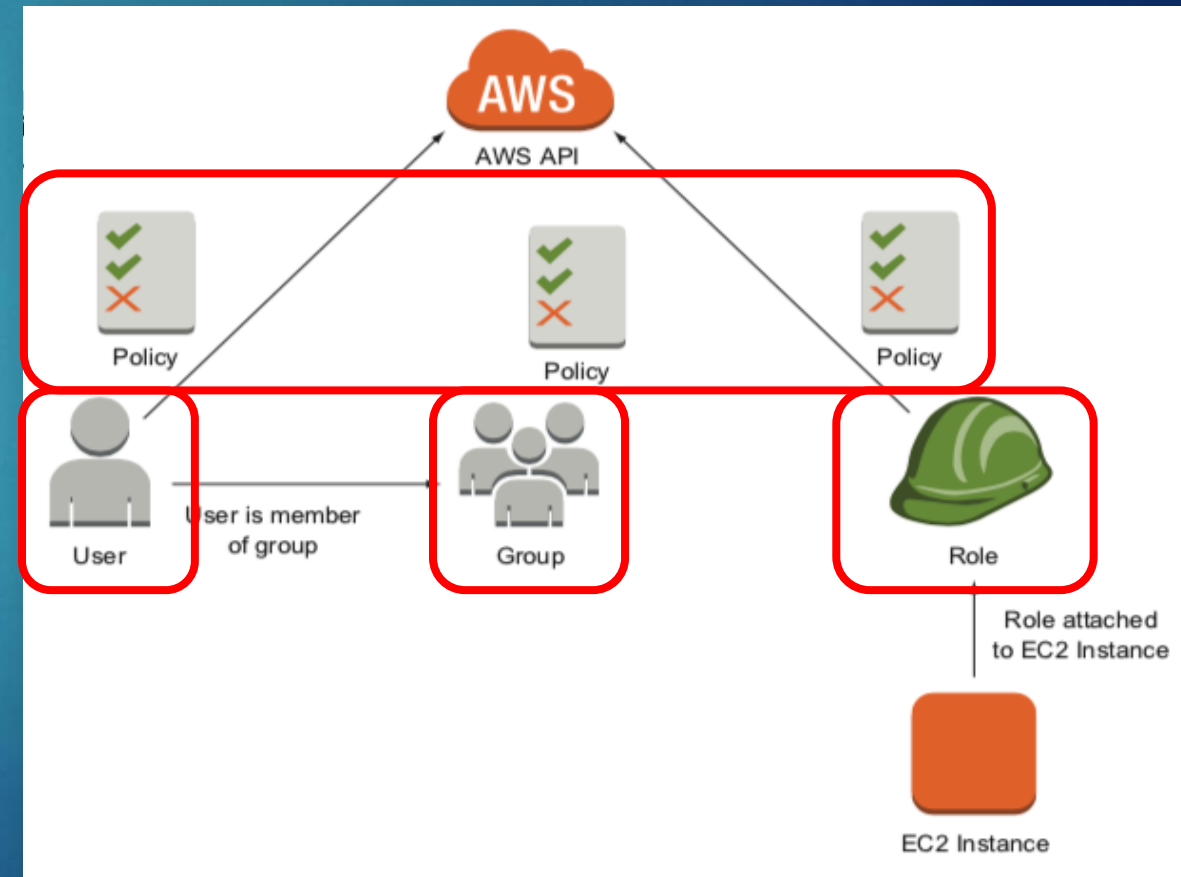
- ▶ A collection of IAM users

- ▶ IAM Role

- ▶ An IAM entity that defines a set of policies (permissions) for making AWS service requests
 - ▶ They are not associated with a specific IAM user or group

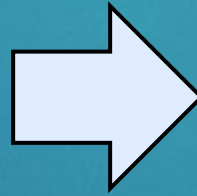
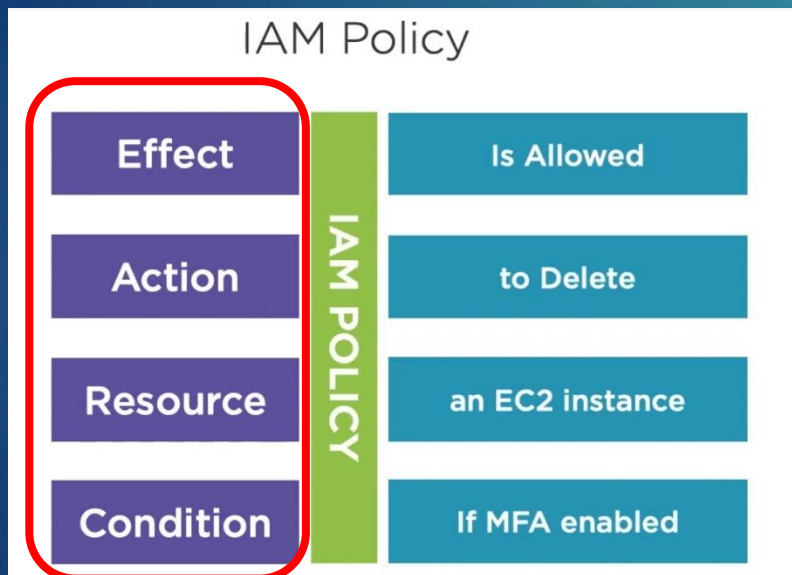
- ▶ IAM Policy

- ▶ Used to define the permissions for a user, group or role



IAM Policy

- ▶ An IAM Policy is an entity that, when attached to an identity or resource, defines their permissions
- ▶ Policies are stored in AWS as JSON documents



IAM Policy Example

```
{  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "VisualEditor0",
      "Effect": "Allow",
      "Action": "ec2:TerminateInstances",
      "Resource": "arn:aws:ec2:us-east-1::instance/*",
      "Condition": {
        "BoolIfExists": {
          "aws:MultiFactorAuthPresent": "true"
        }
      }
    }
  ]
}
```

- ▶ Policies can be either managed or inline

IAM Policy – Managed Policies

- ▶ Standalone identity-based policies that you can attach to users, groups, and roles in your AWS account. There are two types of managed policies:

AWS managed policies

Managed policies that are created and managed by AWS

Policy Name	Type
PersonalizeS3Policy	Customer managed
AmazonDMSRedshiftS3Role	AWS managed
AmazonS3FullAccess	AWS managed

AmazonS3FullAccess
Provides full access to all buckets via the AWS Management Console.

```
1- {
2-   "Version": "2012-10-17",
3-   "Statement": [
4-     {
5-       "Effect": "Allow",
6-       "Action": "s3:*",
7-       "Resource": "*"
8-     }
9-   ]
10- }
```

Full access to S3 for any resource

There are hundreds of policies available

Customer managed policies

Managed policies that you create and manage in your AWS account

Policy Name	Type
PersonalizeS3Policy	Customer managed

PersonalizeS3Policy

```
1- {
2-   "Version": "2012-10-17",
3-   "Id": "PersonalizeS3BucketAccessPolicy",
4-   "Statement": [
5-     {
6-       "Sid": "PersonalizeS3BucketAccessPolicy",
7-       "Effect": "Allow",
8-       "Action": [
9-         "s3:GetObject",
10-        "s3:ListBucket",
11-        "s3:PutObject"
12-       ],
13-       "Resource": [
14-         "arn:aws:s3:::estore-personalize",
15-         "arn:aws:s3:::estore-personalize/*"
16-       ]
17-     }
18-   ]
19- }
```

Get, List and Put permissions only

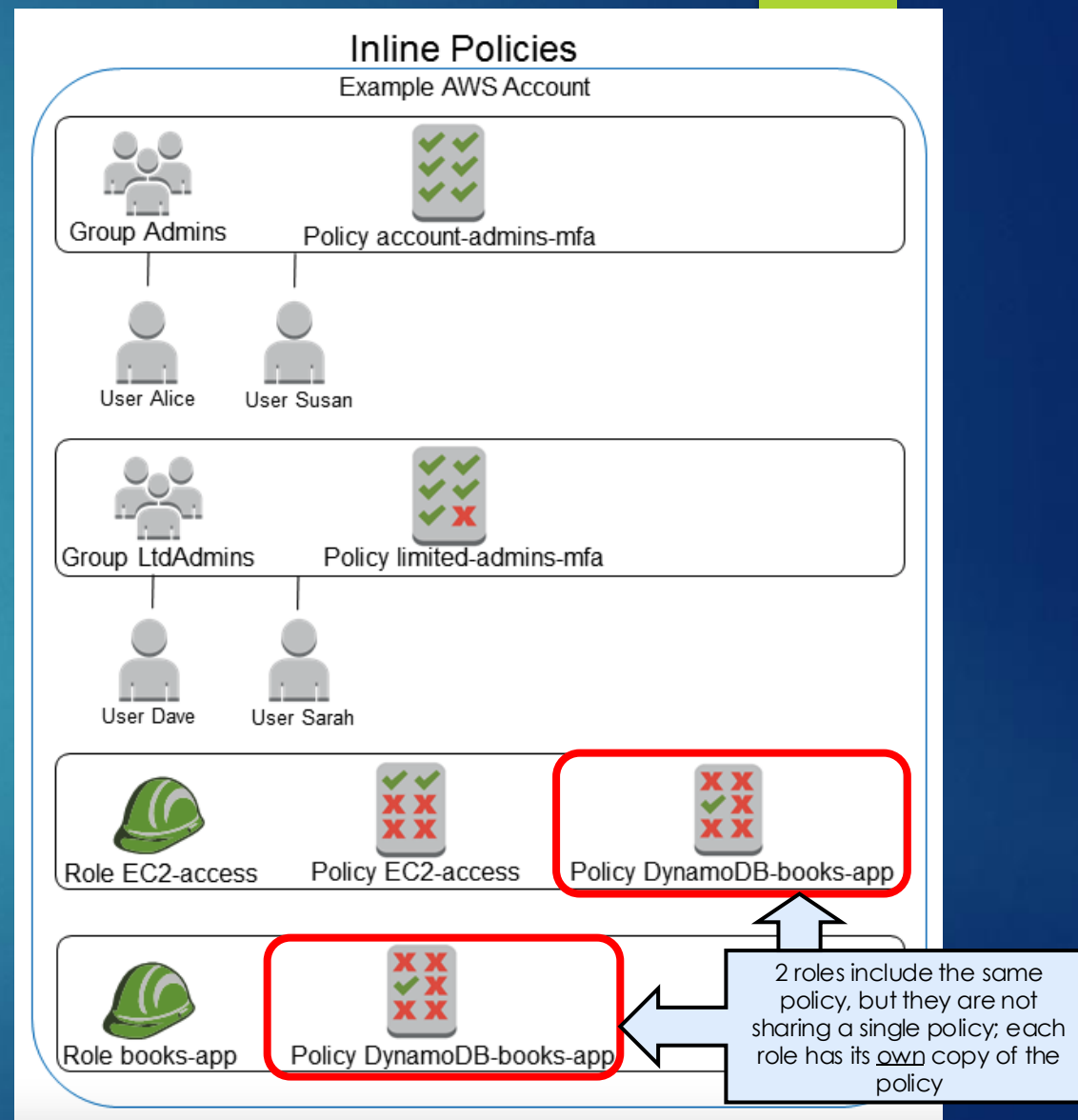
Restricted to resource that is named estore-personalize

They provide more precise control over your policies than AWS managed policies

IAM Policy – Inline Policies

22

- ▶ An inline policy is attached directly to a specific user, group, or role
- ▶ It has a one-to-one relationship where the policy applies only to that identity
- ▶ If the identity is deleted, the inline policy is deleted automatically with it



IAM Policy Example - Lambda

- ▶ By default, Lambdas need access to Amazon CloudWatch Logs for log streaming, so an inline policy is automatically created
- ▶ For the “Create Lambda Function with S3” activity, you created a Lambda function to allow access S3 so you used a managed policy

CloudWatch logging (automatically created)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "logs:CreateLogGroup",
      "Resource": "arn:aws:logs:us-east-1:075837463923:*"
    },
    {
      "Effect": "Allow",
      "Action": [
        "logs:CreateLogStream",
        "logs:PutLogEvents"
      ],
      "Resource": [
        "arn:aws:logs:us-east-1:075837463923:log-group:/aws/lambda/s3-test:*"
      ]
    }
  ]
}
```

Inline Policy

← Create Log Group

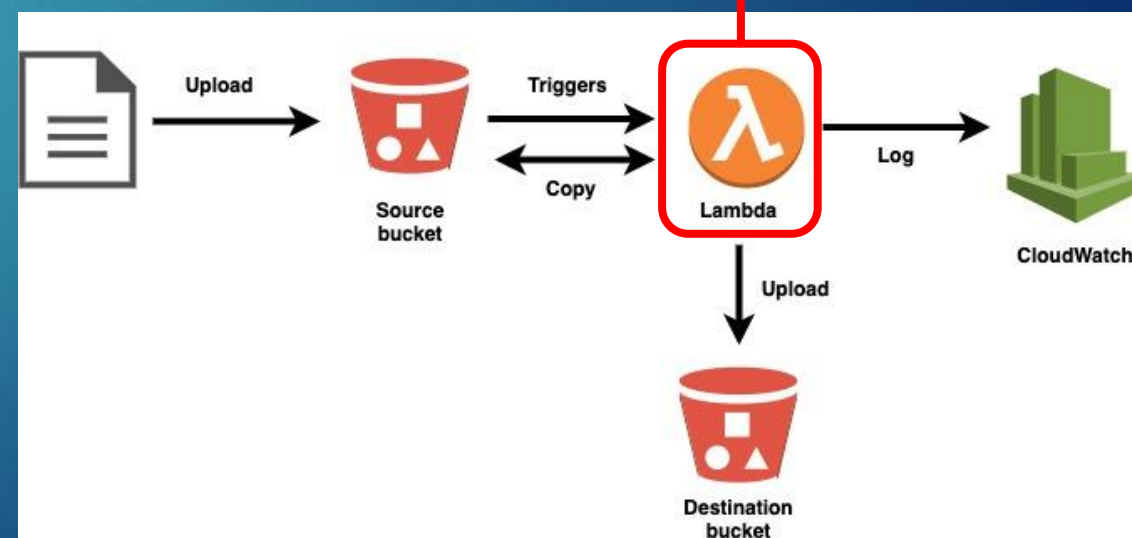
← Create Log stream and log events

↑ Amazon Resource Name (ARN) identifies specific Lambda function called s3-test

AmazonS3FullAccess

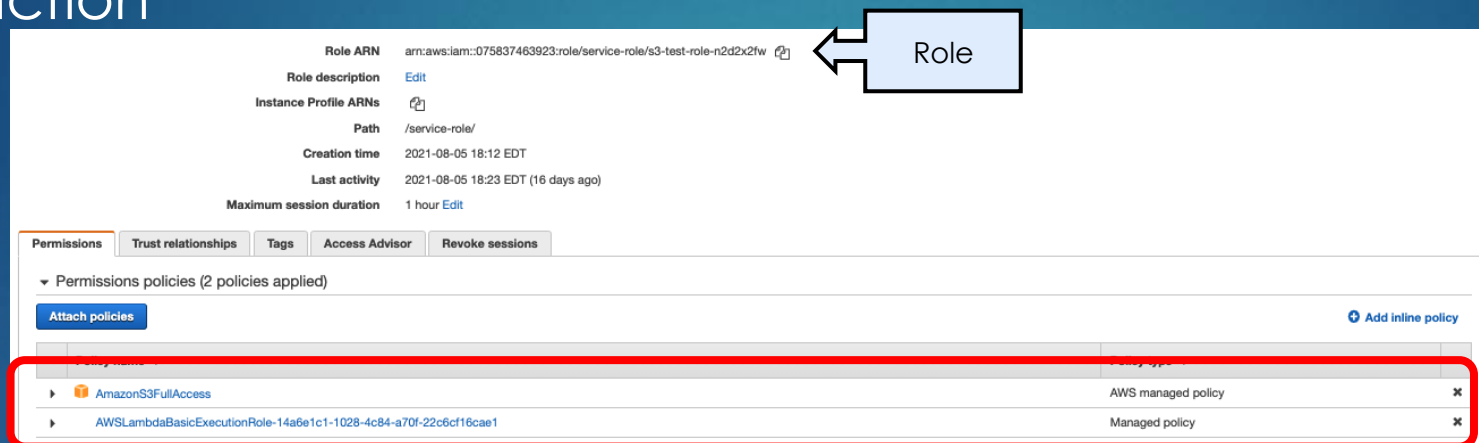
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "s3:*",
      "Resource": "*"
    }
  ]
}
```

Managed Policy



IAM Policy Example - Lambda

- ▶ These policies are associated to an IAM Role that's assigned to your Lambda function

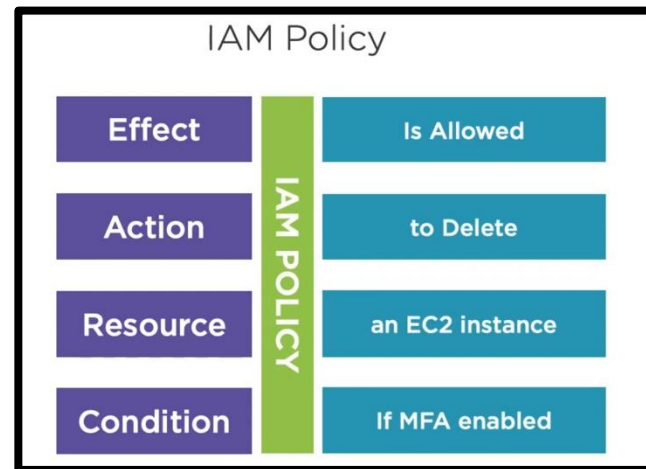


- ▶ You did the same thing for the BONUS part of “Create a DynamoDB” activity

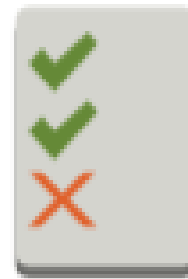


IAM Role

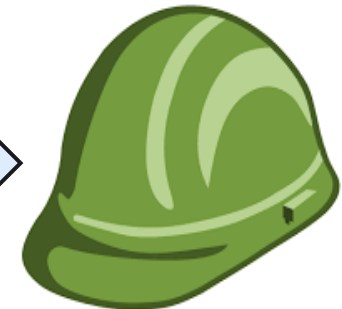
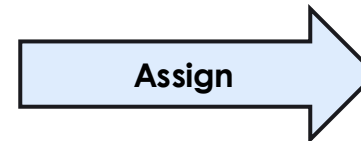
- ▶ An IAM Role is an IAM identity that you can create in your account that has specific permissions (policies)
- ▶ Roles can be created to act as a proxy to allow users or services (e.g EC2 instance or Lambda function) to access resources



Policy Details - Can delete EC2 instances if MFA is enabled



Policy

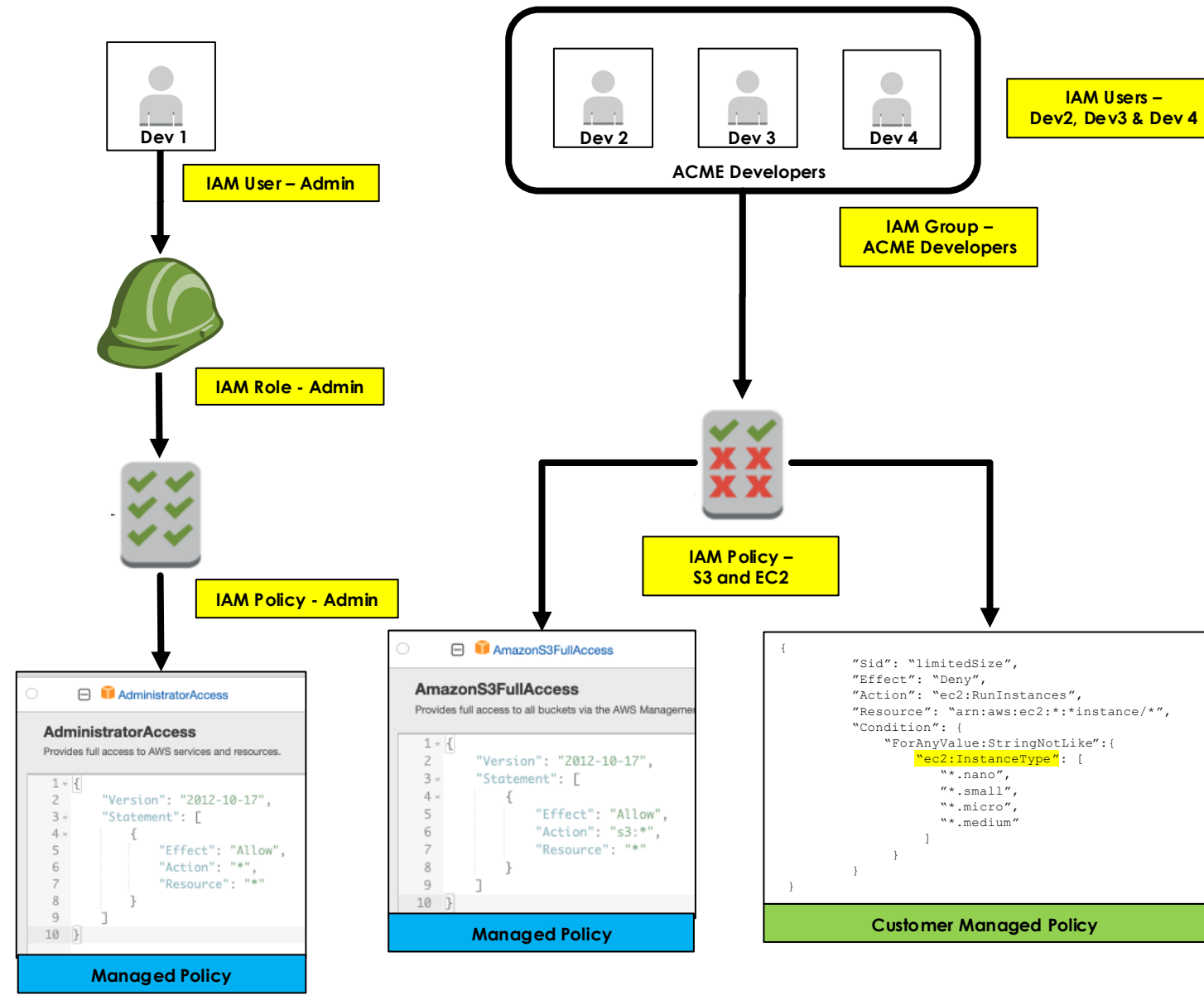


IAM Role

IAM Scenario #1 – User Access

26

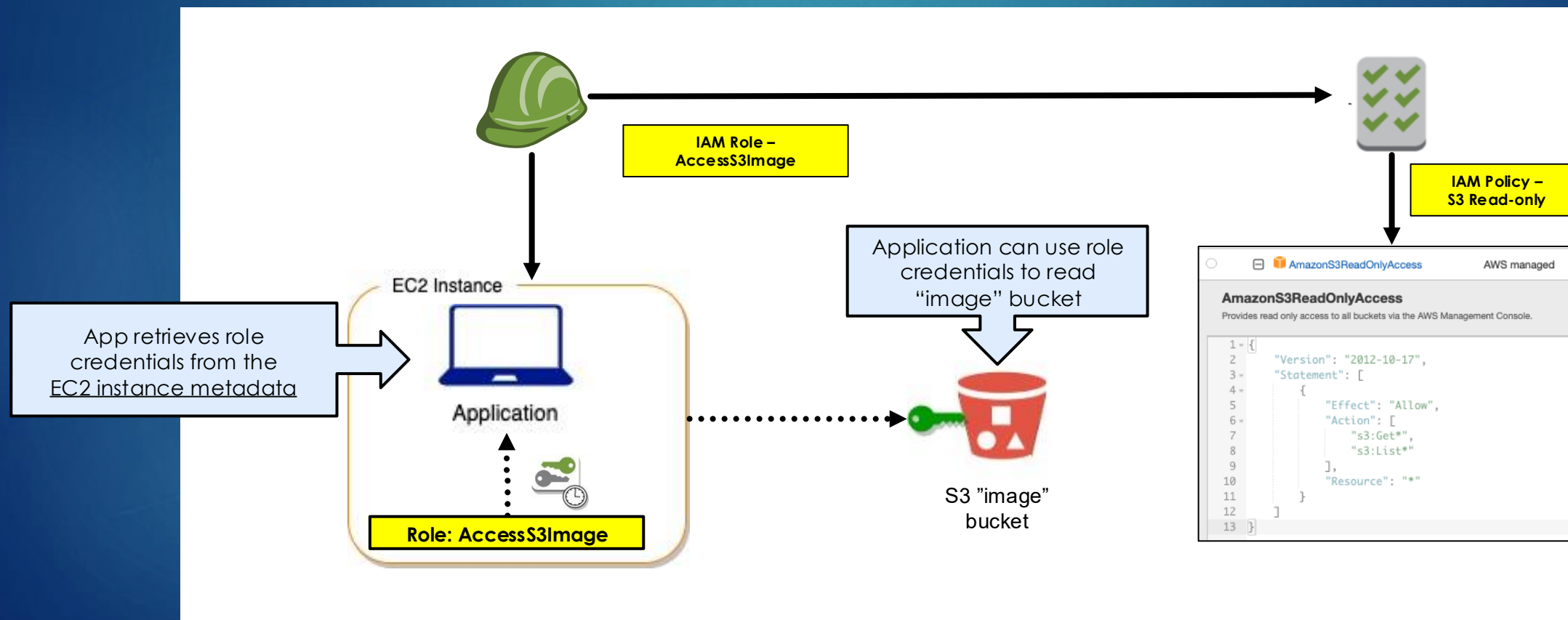
- ▶ The ACME company has an AWS account and needs to define access for its 4 employees
 - ▶ 1 employee can temporarily be the administrator (full access) for the development team
 - ▶ The developers are only allowed to create EC2 and S3
- ▶ Due to budget constraints, developers are only allowed to create EC2 instances that are not larger than medium
- ▶ What's needed for IAM?



IAM Example #2 – Resource Access

27

- ▶ Application on EC2 requires read-only access to S3 “image” bucket
- ▶ What’s needed for IAM?



IAM Example #2 – Application Access

- ▶ IAM Role can be assigned while creating instances or through other configurations (CLI, CloudFormation, etc.)

▼ Advanced details [Info](#)

Purchasing option [Info](#)

☐ Request Spot Instances
Request Spot Instances at the Spot price, capped at the On-Demand price

Domain join directory [Info](#)

Select [Create new directory](#)

IAM instance profile [Info](#)

AccessS3Image
arn:aws:iam::278656840245:instance-profile/AccessS3Image [Create new IAM profile](#)



IAM Best Practices

- ▶ Enable multi-factor authentication (MFA) for privileged users
 - ▶ Presenting two or more pieces of evidence (or factors) to an authentication mechanism
- ▶ Use Policy Conditions for Extra Security
 - ▶ Policies are a set of JSON statements which provide certain permissions to users so to add more security, specific 'Conditions' can be added to policies
- ▶ Remove Unnecessary Credentials (Principle of Least Privilege)
 - ▶ Regularly audit user credentials and remove them in case they are not in use
- ▶ Use AWS-Defined Policies to Assign Permissions
 - ▶ A major benefit of using these policies is the auto-update functionality as new or updated policies are introduced
- ▶ Use Groups to Assign Permissions to IAM Users
 - ▶ Managing permissions is not only easier but more secure and manageable
 - ▶ For example, whenever there are inter-departmental moves, one simply needs to place the individual in another group rather than redefining the whole set of permissions

Securing Your Applications with AWS Cognito

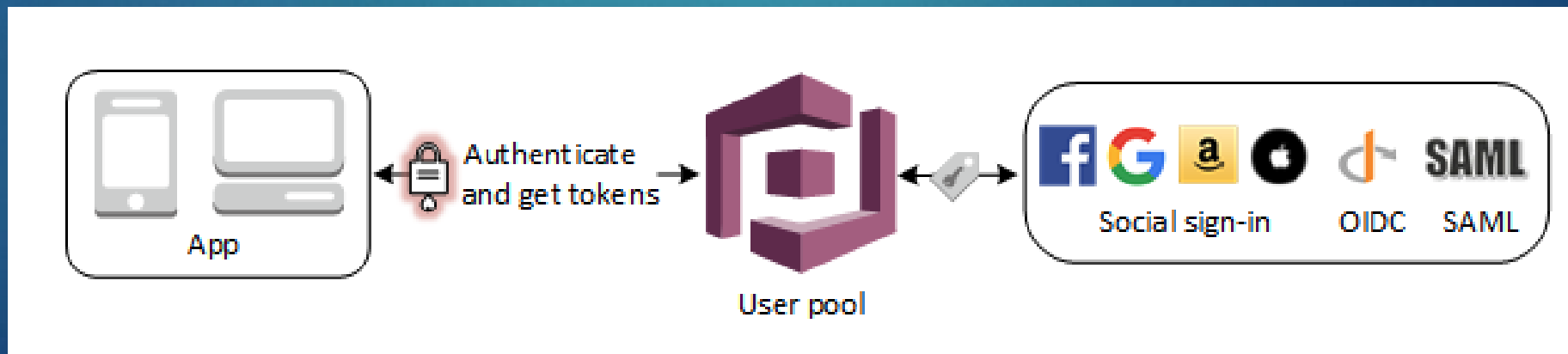
30

- ▶ User Identify and Data Synchronization service
- ▶ Manage user data across multiple mobile or connected devices
 - ▶ User data can be app preferences, game states, etc.
- ▶ Provide a secure user directory that scales to hundreds of millions of users
- ▶ The two main components of Amazon Cognito are user pools and identity pools



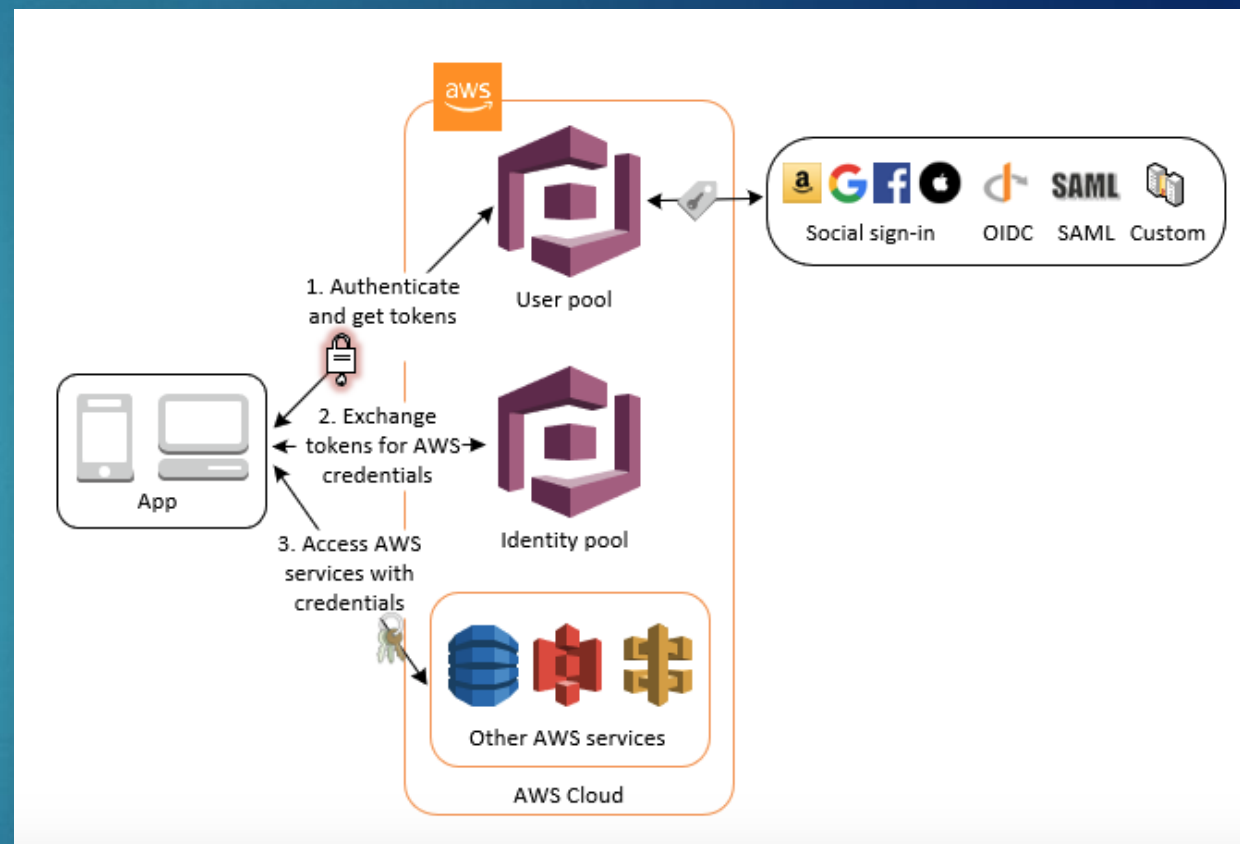
AWS Cognito – User Pools

- ▶ A user pool is a user directory in Amazon Cognito that stores and manages your app's users. It handles user registration, authentication, and account recovery.
- ▶ Users can sign in directly through the user pool or federate through external identity providers (such as Google, Facebook, Amazon, Apple, or enterprise IdPs using OIDC or SAML)
- ▶ A Cognito user pool stores user profiles (including federated users), but delegates authentication to the external identity provider



AWS Cognito – Identity Pools

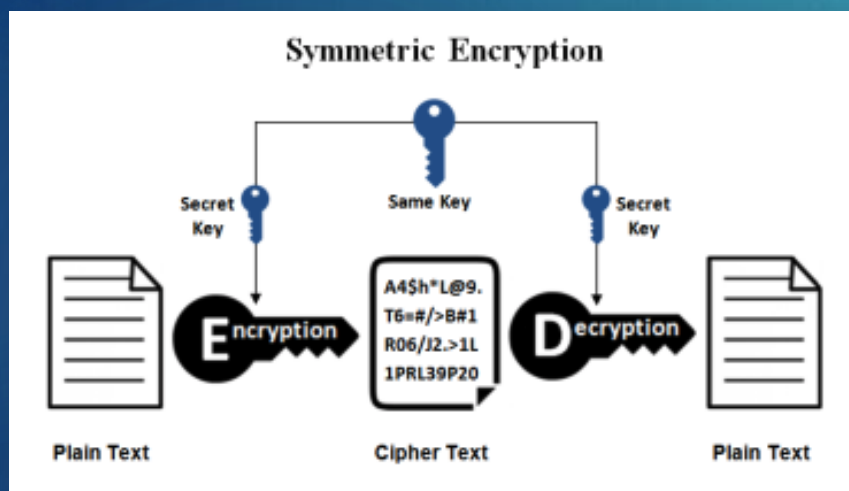
- ▶ An identity pool provides authorization by controlling what AWS resources a user can access
- ▶ Identity pools create unique identities for users and assign them temporary AWS credentials through IAM roles
- ▶ Once authenticated, users can directly access other AWS services (such as S3, DynamoDB, or Lambda) based on the permissions granted by the identity pool's IAM roles



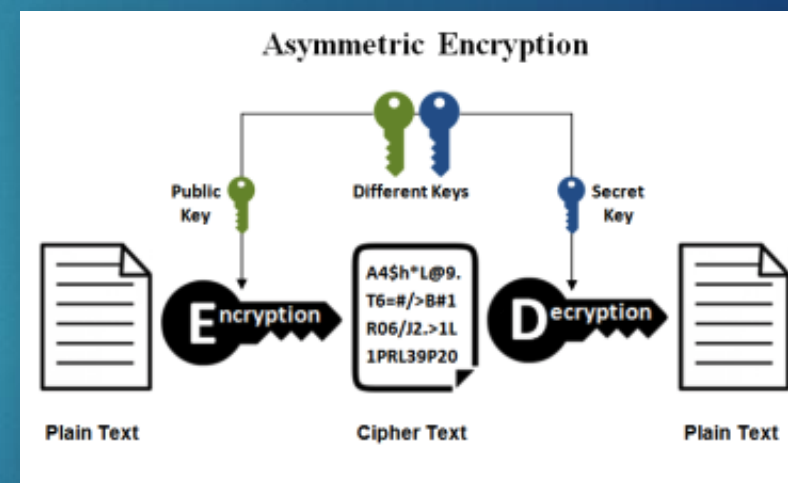
Protecting Data with Encryption – Overview

33

- ▶ To encrypt data message, you need a key to start an encryption and you need a key to decrypt the message
- ▶ If someone is listening and hijacks the data, they can't read it because they don't have the proper keys to unlock the message



Some of the most widely used encryption algorithms are AES-128, AES-192, and AES-256

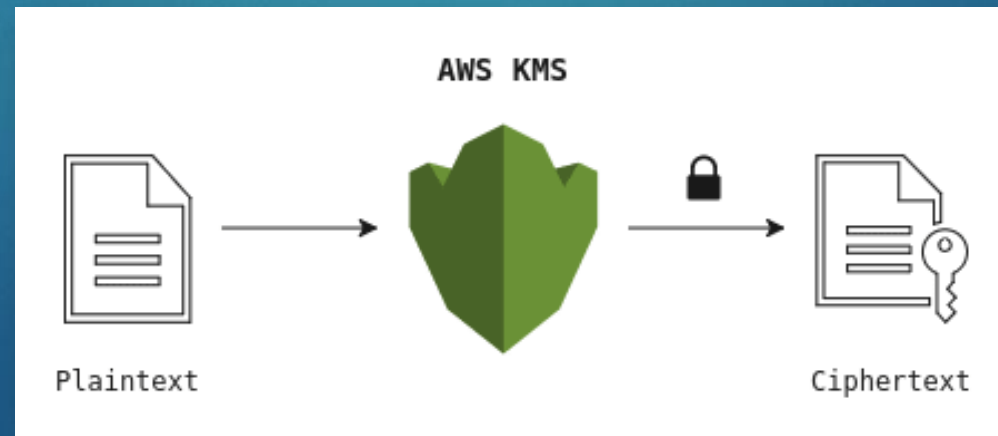


This type of encryption both the sender and the receiver need to have the same key in order to make an encryption or decryption.

This type of encryption has two keys one public and one private, the public key is available to anyone who wants to send you data but the private key only the receiver has it, this way only the owner of that key can decrypt the message

Encryption on AWS

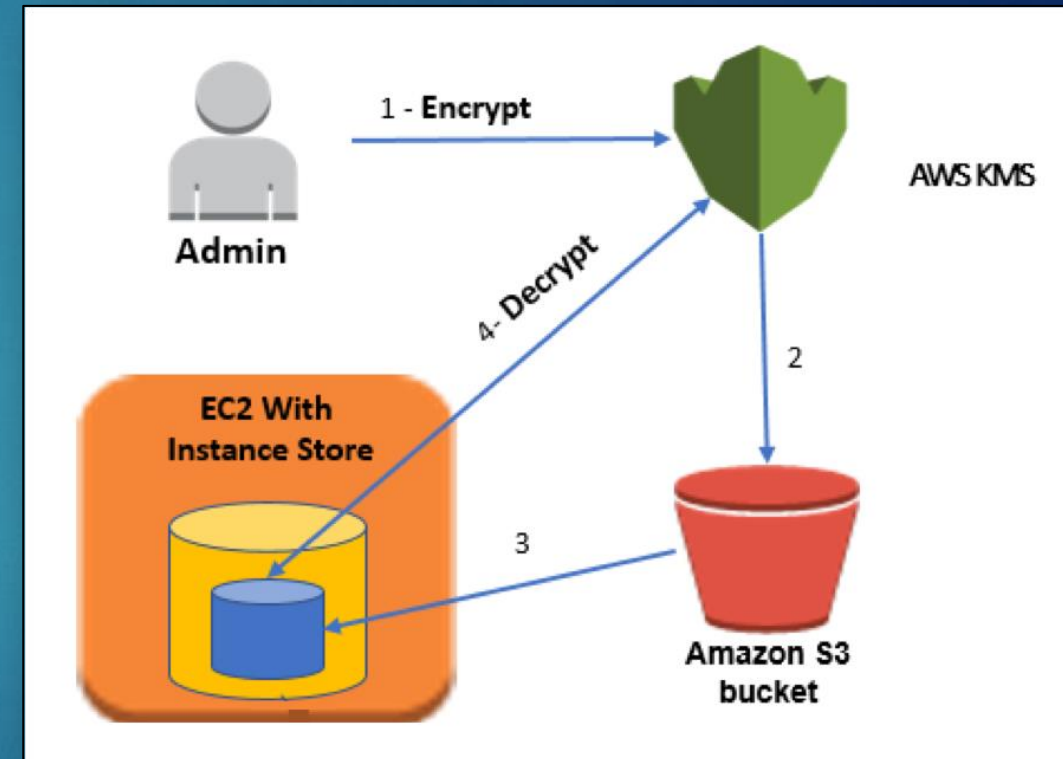
- ▶ Encrypting data at rest is vital for regulatory compliance to ensure that sensitive data saved on disks is not readable by any user or application without a valid key
- ▶ Some compliance regulations such as PCI and HIPAA require that data at rest be encrypted throughout the data lifecycle
- ▶ AWS Key Managed Service (KMS) is a fully managed service that makes it easy to create and control encryption keys on AWS which can then be utilized to encrypt and decrypt data in a safe manner



Securing a Linux Encrypted File System with AWS KMS

35

1. The administrator uses AWS KMS to encrypt a secret password
2. The encrypted password file is stored in an Amazon S3 bucket
3. During instance startup, the EC2 instance copies the encrypted file from S3 to its local disk
4. The instance then uses KMS to decrypt the file and retrieve the secret password
 - ▶ The password is used to configure a Linux encrypted file system
 - ▶ All data written to that file system is encrypted on disk using AES-256



AWS KMS integration

- ▶ Several AWS services such as S3 (see right), Elastic Block Store (EBS), Amazon Relational Database Service (RDS) and DynamoDB integrate with KMS
- ▶ These can be combined with IAM policies to provide another layer of control

[Amazon S3](#) > [Buckets](#) > [mz-dynamo-db](#) > Edit default encryption

Edit default encryption [Info](#)

Default encryption
Server-side encryption is automatically applied to new objects stored in this bucket.

Encryption type [Info](#)

- ☒ Server-side encryption with Amazon S3 managed keys (SSE-S3)
- ☐ Server-side encryption with AWS Key Management Service keys (SSE-KMS)
- ☐ Dual-layer server-side encryption with AWS Key Management Service keys (DSSE-KMS)
Secure your objects with two separate layers of encryption. For details on pricing, see [DSSE-KMS pricing](#) on the **Storage** tab of the [Amazon S3 pricing page](#).

Bucket Key
Using an S3 Bucket Key for SSE-KMS reduces encryption costs by lowering calls to AWS KMS. S3 Bucket Keys aren't supported for DSSE-KMS. [Learn more](#)

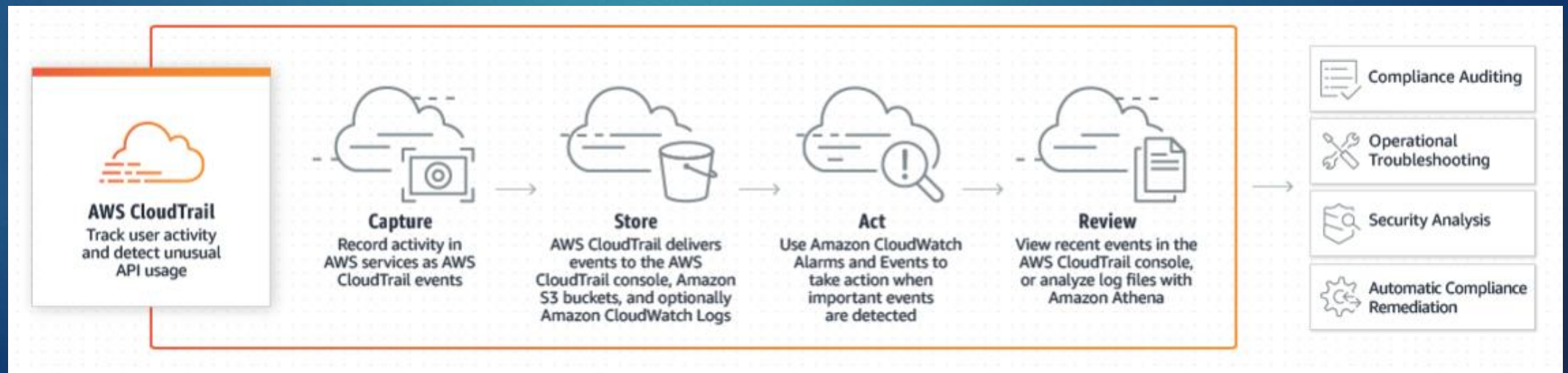
- ☐ Disable
- ☒ Enable

[Cancel](#) [Save changes](#)

You can set encryption under “Properties” for your S3 bucket

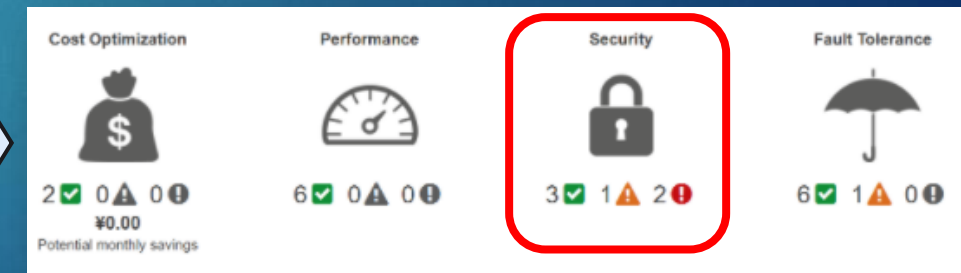
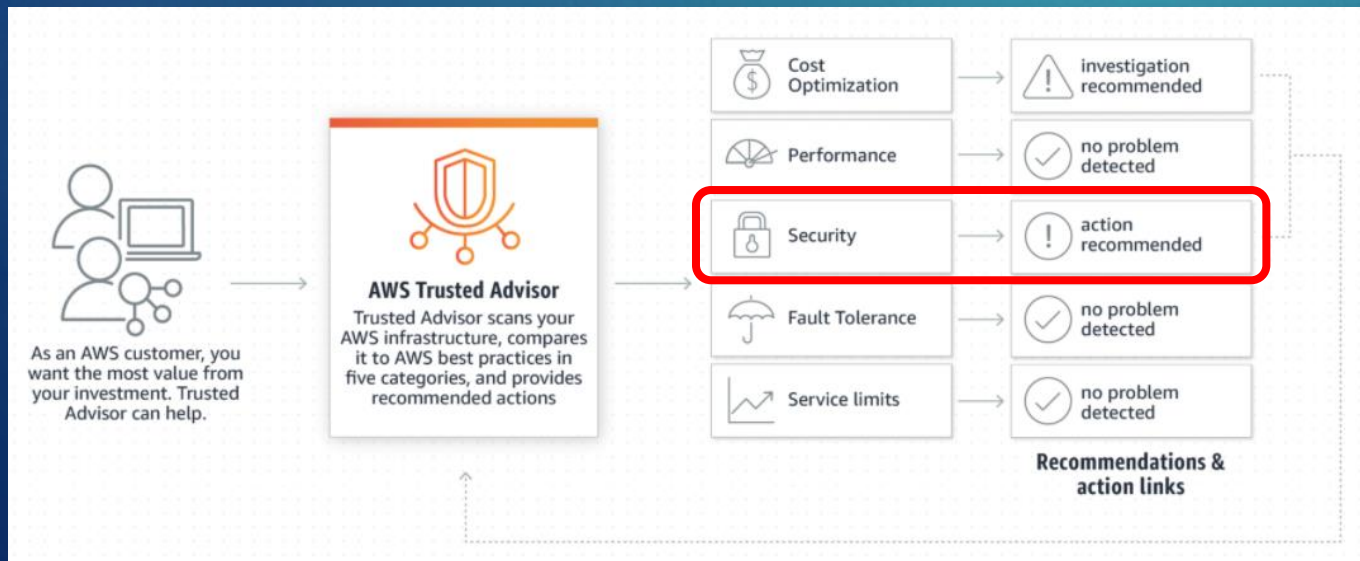
Compliance and Audit - CloudTrail

- ▶ AWS CloudTrail is a service that enables governance, compliance, operational auditing, and risk auditing of your AWS account
- ▶ It provides event history of your AWS account activity, including actions taken through the AWS Management Console, SDKs, command line tools, and other AWS services
- ▶ It can also provide the logs of all key usage, which may be required for regulatory and compliance needs
- ▶ This event history simplifies security analysis, resource change tracking, and troubleshooting to even detect unusual activity in your AWS accounts



How secure are you?

- ▶ AWS Trusted Advisor is an online tool that provides you real time guidance to help you provision your resources following AWS best practices
- ▶ For Security, Trusted Advisor scans for the following:
 - ▶ Checks security groups for rules that allow unrestricted access (0.0.0.0/0) to specific ports
 - ▶ Checks security groups for rules that allow unrestricted access to a resource
 - ▶ Checks buckets in S3 that have open access permissions





- ▶ Going back to your scenarios, you've been asked to identify what areas might have security risks and what your plan is to address them
 - ▶ What type of Compliance issues would you need to deal with?
 - ▶ Identify 2-3 potential security issues/threats that might be associated with your scenario
 - ▶ What features of IAM could help with your scenario?
 - ▶ What other types of checks or precautions would you recommend in order to protect against these threats?
- ▶ Download the template from [Assignments > Activity - Security Plan](#)
 - ▶ 1 submission per team
- ▶ Scenarios located at: [Assignment > Activity - Cost Estimating Scenarios](#)